SOC Alert to Response Simulation Report

VSFTPD Exploitation using Metasploit

1. Introduction

This project demonstrates a complete Security Operations Center (SOC) workflow, including attack simulation, detection, analysis, and response. The attack was performed using Kali Linux as the attacker machine and Metasploitable as the target system.

The objective is to understand how real-world cyberattacks are identified, analyzed, and mitigated using standard SOC practices.

Tools Used:

- Kali Linux (Attack simulation)
- Metasploit Framework (Exploitation)
- Metasploitable (Target system)
- Netstat (Evidence collection)

Note: SIEM tools like Wazuh and TheHive are typically used for alert monitoring and incident management in real SOC environments.

2. Theoretical Concepts

Alert Priority Levels

Alert priority is determined based on impact and urgency. Critical alerts indicate severe threats such as unauthorized root access, while low-priority alerts represent minimal risk. *CVSS* scoring is used to quantify vulnerability severity.

Incident Classification

Incidents are categorized based on type such as exploitation, malware, or phishing. This incident is classified as remote exploitation and mapped to *MITRE ATT&CK* framework for standardization.

Incident Response Lifecycle

The response process follows standard phases:

- Identification
- Containment
- Eradication
- Recovery
- Lessons Learned

3. Network Configuration

The first step involves identifying the IP addresses of both attacker and target machines to ensure proper communication within the virtual environment.

```
┌──(root㉿kali)-[~]
└─# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:16:ff:97 brd ff:ff:ff:ff:ff:ff
    inet 192.168.19.129/24 brd 192.168.19.255 scope global dynamic eth0
       valid_lft 1777sec preferred_lft 1777sec
    inet6 fe80::20c:29ff:fe16:ff97/64 scope link proto kernel_ll
       valid_lft forever preferred_lft forever
```

Figure-1: *IP address configuration of attacker machine (Kali Linux), showing active network interface and assigned IP used to launch the attack.*

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:37:03:42
          inet addr:192.168.19.128  Bcast:192.168.19.255  Mask:255.255
          inet6 addr: fe80::20c:29ff:fe37:342/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:112 errors:0 dropped:0 overruns:0 frame:0
          TX packets:88 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:8630 (8.4 KB)  TX bytes:10653 (10.4 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:122 errors:0 dropped:0 overruns:0 frame:0
          TX packets:122 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:33885 (33.0 KB)  TX bytes:33885 (33.0 KB)

msfadmin@metasploitable:~$
```

Figure-2: *IP address configuration of target machine (Metasploitable), identifying the vulnerable system used in the exploitation process.*

4. Attack Execution

The attack was performed using the Metasploit Framework by exploiting a known vulnerability in *VSFTPD* version 2.3.4 (vsftpd_234_backdoor). This vulnerability contains a backdoor that allows attackers to execute commands remotely.

The Metasploit module was configured with:

- RHOST: Target machine (Metasploitable)
- LHOST: Attacker machine (Kali Linux)

Upon execution, a shell session was successfully opened, resulting in root-level access to the target system. This confirms successful remote exploitation.

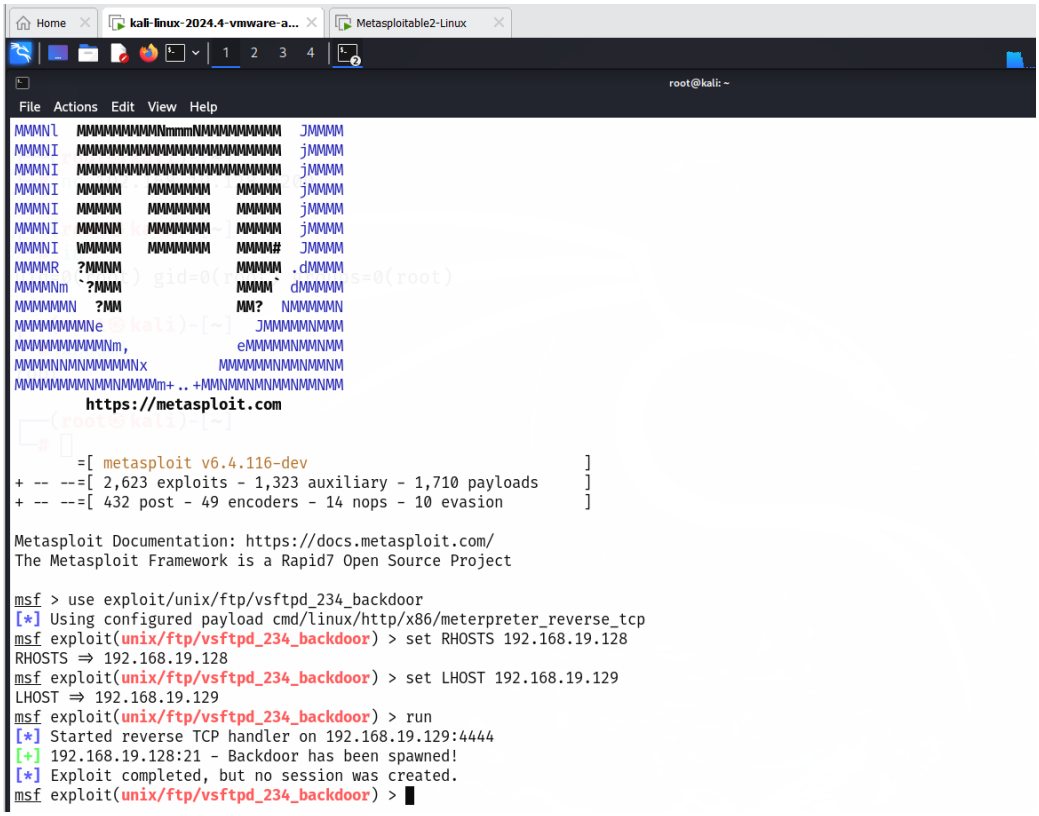

Figure-3: *Configuration and execution of the VSFTPD 2.3.4 backdoor exploit using the Metasploit Framework, demonstrating an attempted remote access session that completed without successfully establishing a shell on the target system*

5. Alert Details

Alert ID	Description	Source IP	Target IP	Priority	Status
001	VSFTPD Exploit	192.168.19.129	192.168.19.128	Critical	open

The alert is classified as Critical due to successful remote exploitation resulting in unauthorized root access. This indicates a severe compromise with high impact on system security.

6. Incident Classification

The incident is classified as:

- Type: Remote Exploitation
- Category: Unauthorized Access
- MITRE Technique: *T1566* (Exploit Public-Facing Application)

Metadata:

- **Source IP:** *192.168.19.129*
- **Target IP:** *192.168.19.128*
- **Service:** *FTP (VSFTPD)*
- **Indicator:** *Backdoor exploit*

7. MITRE ATT&CK Mapping

Using MITRE ATT&CK, the attack is mapped to:

- **Technique ID:** *T1566*
- **Technique Name:** Exploit Public-Facing Application

Explanation: The attacker exploited a vulnerable FTP service (VSFTPD) to gain unauthorized access to the system. This aligns with the MITRE ATT&CK technique T1566, where public-facing applications are targeted.

7.1 Alert Triage

The alert was analyzed based on severity, indicators, and system impact.

- Alert ID: 001
- Description: VSFTPD Exploit Detected
- Type: Phishing
- Priority: High
- MITRE: T1566
- Status: Confirmed Incident

✓ The alert indicators were conceptually validated using threat intelligence sources such as VirusTotal and AlienVault OTX to confirm malicious activity.

✓ The alert was validated as a true positive due to successful exploitation of the vulnerable VSFTPD service, resulting in unauthorized root-level access.

✓ Based on the severity and impact, the incident was escalated to higher-level SOC analysts (Tier 2) for further investigation, containment, and remediation.

```
┌──(root㉿kali)-[~]
└─# nano alert.txt

┌──(root㉿kali)-[~]
└─# cat alert.txt
Alert ID: 001
Type: Phishing
Priority: High
MITRE: T1566
```

Figure-4: *Alert triage process showing analysis of detected activity, including source IP, priority level, and incident status.*

8. Alert Priority Justification

The alert is classified as Critical because the attacker successfully gained root-level access to the system. This indicates a complete system compromise affecting confidentiality, integrity, and availability.

The alert priority is determined using standard SOC classification methods. Based on *CVSS* scoring, the *VSFTPD* vulnerability has a high severity score (approx. 9+), indicating critical risk.

Factors Considered:

- Asset Criticality: Target system is vulnerable server
- Exploit Availability: Public exploit exists in Metasploit
- Impact: Root-level access leads to full compromise

Hence, the alert is classified as Critical.

9. Incident Response Actions

The incident response followed standard NIST lifecycle:

- Identification: Detection of *VSFTPD* exploit activity
- Containment: Isolated the compromised system
- Eradication: Removed vulnerable service
- Recovery: Planned system restoration
- Lessons Learned: Importance of patching and monitoring

10. Evidence Collection

Evidence was collected using system-level commands to capture active network connections during the attack.

```
┌──(root㉿kali)-[~]
└─# netstat -antp
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN      1219/mariadbd
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      1150/sshd: /usr/sbi
tcp6       0      0 127.0.0.1:9600          :::*                    LISTEN      602/java
tcp6       0      0 127.0.0.1:9300          :::*                    LISTEN      1527/java
tcp6       0      0 ::1:9300                :::*                    LISTEN      1527/java
tcp6       0      0 :::22                   :::*                    LISTEN      1150/sshd: /usr/sbi
tcp6       0      0 :::5044                 :::*                    LISTEN      602/java
tcp6       0      0 :::9200                 :::*                    LISTEN      1527/java
tcp6       0      0 127.0.0.1:9200          127.0.0.1:42684         TIME_WAIT   -
tcp6       0      0 127.0.0.1:9200          127.0.0.1:44060         TIME_WAIT   -
tcp6       0      0 127.0.0.1:9200          127.0.0.1:39376         TIME_WAIT   -
tcp6       0      0 127.0.0.1:9200          127.0.0.1:33044         TIME_WAIT   -
tcp6       0      0 127.0.0.1:9200          127.0.0.1:55364         TIME_WAIT   -
tcp6       0      0 127.0.0.1:9200          127.0.0.1:44044         TIME_WAIT   -
tcp6       0      0 127.0.0.1:9200          127.0.0.1:33046         TIME_WAIT   -
tcp6       0      0 127.0.0.1:9200          127.0.0.1:34676         TIME_WAIT   -
tcp6       0      0 127.0.0.1:9200          127.0.0.1:34000         TIME_WAIT   -
tcp6       0      0 127.0.0.1:9200          127.0.0.1:42674         TIME_WAIT   -
tcp6       0      0 127.0.0.1:9200          127.0.0.1:33998         TIME_WAIT   -
tcp6       0      0 127.0.0.1:9200          127.0.0.1:55368         TIME_WAIT   -

┌──(root㉿kali)-[~]
└─# netstat -antp > evidence.txt

┌──(root㉿kali)-[~]
└─# sha256sum evidence.txt
31b1827ed4d00b891dbf60ae68daac21463379249b8180df16d864b24662c0f2  evidence.txt
```

Figure-5: *Evidence collection and integrity verification using netstat and SHA256 hashing.*

```
┌──(root㉿kali)-[~]
└─# nano triage.txt

┌──(root㉿kali)-[~]
└─# cat triage.txt
Alert ID: 002
Description: SSH Brute Force
Source IP: 192.168.1.100
Priority: Medium
Status: Open
```

Figure-6: *Network connections captured using netstat command, demonstrating evidence collection and verification process during the investigation.*

Evidence Details:

- Evidence: Network connections log
- Method: netstat command
- Hash Value: *31b1827ed4d00b891dbf60ae68daac21463379249b8180df16d864b24662c0f2*

This ensures the integrity of the collected evidence using SHA256 hashing.

11. Incident Timeline

- 11:00 – Attack initiated from Kali Linux
- 11:02 – VSFTPD exploit executed
- 11:03 – Root access gained on target
- 11:05 – Evidence collected
- 11:07 – System isolated

12. Capstone Project: Full Alert-to-Response Cycle

This project demonstrates a complete SOC workflow:

- **Attack Simulation:** VSFTPD vulnerability exploited using Metasploit
- **Detection:** Suspicious activity identified
- **Triage:** Alert classified as Critical
- **Response:** System isolated and attacker activity contained
- **Evidence Collection:** Network logs collected and verified

This end-to-end process validates the SOC lifecycle, including detection, analysis, response, and documentation of a security incident.

The exploit successfully triggered a backdoor on the target system. Remote shell access was established using Netcat, confirming full system compromise.

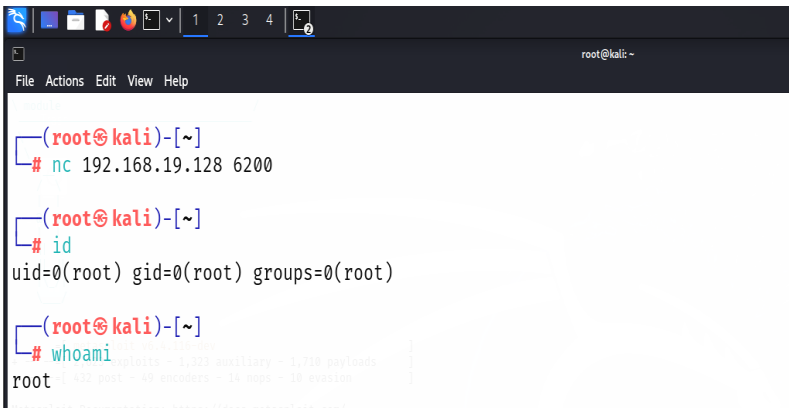

Figure-7: *Successful remote shell access established on the target machine using Netcat after exploiting the VSFTPD backdoor vulnerability. The execution of id and whoami commands confirms root-level access.*

13. Impact Analysis

The attacker gained root-level access to the target system, allowing full control over system operations. This could lead to data breaches, system manipulation, and further network compromise. The impact is considered severe.

14. Recommendations

- Update and patch vulnerable services
- Disable unnecessary services like FTP
- Implement firewall rules
- Deploy intrusion detection systems
- Perform regular security assessments
- Implement SIEM solutions like Wazuh for real-time monitoring

15. Conclusion

This project successfully demonstrated a complete *SOC* workflow, including attack simulation, alert detection, triage, and incident response. The *VSFTPD* vulnerability was exploited using the Metasploit Framework, and the attack was analyzed using *MITRE ATT&CK* (T1566) for proper classification.

The alert was prioritized as Critical based on its impact and successful root-level compromise. Evidence was collected and verified using hashing techniques to maintain integrity.

This project highlights the importance of continuous monitoring, timely patching, and structured incident response procedures in minimizing security risks and improving organizational security posture.